

Manual 16 — Implementação Controlada ISO/IEC 27001 / 27002

Edição controlada pt-BR — candidata de desenvolvimento

****Ordem da série:**** 16

****Fonte inglesa congelada:**** `controlled/en/MANUAL\_16\_CONTROLLED\_EN.md`

****SHA do blob-fonte:**** `0a4d1e84cf4844be1685287a441392b7a1fa6c25`

****Linha de base autoritativa:**** ISO/IEC 27001:2022; ISO/IEC 27001:2022/Amd 1:2024; ISO/IEC 27002:2022

Limite de publicação e padrões

Este é um manual independente de implementação. Não é uma publicação da ISO, não reproduz texto protegido de cláusulas ou controles ISO/IEC, não concede certificação e não substitui normas licenciadas. A ISO/IEC 27001 contém requisitos para um SGSI; a ISO/IEC 27002 fornece orientação para implementação de controles. Decisões sobre Declaração de Aplicabilidade, tratamento de riscos, auditoria, certificação e conformidade dependem do contexto e exigem evidência competente e julgamento profissional apropriado.

Capítulo 1 — Propósito, governança e modelo operacional do SGSI

Defina por que o SGSI existe, quais resultados de negócio protege e como a governança converte objetivos de segurança em decisões operacionais com responsáveis claros. Designe patrocinador executivo, proprietário do SGSI, proprietários de risco, proprietários de controles e custodiante de evidências.

Capítulo 2 — Contexto organizacional e partes interessadas

Identifique condições internas e externas que possam afetar os resultados de segurança da informação. Mantenha registro de contexto cobrindo estratégia, tecnologia, fornecedores, obrigações legais, ameaças e condições físicas materiais. Documente a análise de relevância climática sem presumir materialidade automática.

Capítulo 3 — Escopo e limites do SGSI

Defina escopo compreensível, defensável e operacionalmente real. Identifique entidades, serviços, locais, aplicações, nuvem, redes, pessoas, fornecedores e fluxos de informação incluídos. Registre interfaces, dependências e exclusões justificadas.

Capítulo 4 — Liderança, política e responsabilização

A alta administração deve estabelecer direção, aprovar a política de segurança, atribuir responsabilidades e assegurar autoridade e recursos suficientes. Converta compromissos em objetivos mensuráveis e decisões registradas.

Capítulo 5 — Funções, responsabilidades e segregação

Documente quem possui riscos, opera controles, revisa evidências, aprova exceções e executa garantia independente. Evite combinações incompatíveis de acesso, aprovação e revisão quando criarem risco inaceitável.

Capítulo 6 — Metodologia de avaliação de riscos

Defina critérios repetíveis para identificar, analisar e avaliar riscos. Especifique ativos ou serviços, ameaças e vulnerabilidades, escalas de probabilidade e impacto, risco inerente e residual, autoridade de aceitação e gatilhos de reavaliação.

Capítulo 7 — Tratamento e aceitação de riscos

Para cada risco material, selecione estratégia de tratamento, vincule ações a objetivos de controle, responsáveis, prazos e evidências e avalie explicitamente o risco residual. A aceitação deve ser feita por autoridade definida.

Capítulo 8 — Governança da Declaração de Aplicabilidade

Use a Declaração de Aplicabilidade como registro de governança que conecta riscos e obrigações aos controles necessários. Não trate o Anexo A como checklist universal obrigatório. Registre justificativas de inclusão ou exclusão, status e evidências.

Capítulo 9 — Objetivos de segurança da informação e planejamento

Defina objetivos mensuráveis alinhados à política e ao contexto. Cada objetivo deve ter proprietário, métrica, meta, frequência ou prazo e fonte de evidência.

Capítulo 10 — Recursos, competência e conscientização

Identifique pessoas, orçamento, ferramentas, infraestrutura e conhecimento necessários. Defina competência por função e preserve evidências adequadas. A conscientização deve cobrir políticas, comportamento esperado, incidentes e obrigações específicas.

Capítulo 11 — Comunicações e informação documentada

Defina o que deve ser comunicado, a quem, quando e por qual canal. Controle documentos e registros por propriedade, versão, aprovação, retenção e acesso. Diferencie registros autoritativos de notas de trabalho.

Capítulo 12 — Planejamento e controle operacional

Converta decisões de tratamento em procedimentos repetíveis com gatilhos, responsáveis, frequência, evidência, exceções e escalonamento. Integre controles com mudança, serviços, engenharia e operações normais.

Capítulo 13 — Governança de ativos e classificação da informação

Mantenha inventários atuais de informações, sistemas, serviços, dispositivos, repositórios e dependências críticas. Atribua propriedade e classificação conforme sensibilidade, obrigações e impacto.

Capítulo 14 — Gestão de identidade e acesso

Defina o ciclo de vida de identidades da admissão ao desligamento. Aplique menor privilégio, acesso compatível com função, revisões periódicas e revogação tempestiva. Preserve rastreabilidade das decisões.

Capítulo 15 — Acesso privilegiado e autenticação

Aplique governança reforçada a acessos administrativos e de alto impacto. Use autenticação apropriada, limite privilégios permanentes quando viável, monitore atividades e governe exceções.

Capítulo 16 — Criptografia e gestão de chaves

Defina quando proteção criptográfica é necessária segundo risco, obrigações e classificação. Governe algoritmos, protocolos, certificados e todo o ciclo de vida de chaves.

Capítulo 17 — Segurança física e ambiental

Proteja instalações, equipamentos e mídias segundo criticidade e risco. Defina acesso físico, visitantes, monitoramento, áreas seguras, controles ambientais e descarte seguro.

Capítulo 18 — Operações, logs e monitoramento

Estabeleça procedimentos operacionais controlados. Defina logging, sincronização de tempo, proteção de registros, casos de uso de monitoramento, responsáveis, retenção e escalonamento. Teste geração e revisão de eventos críticos.

Capítulo 19 — Gestão de vulnerabilidades e configuração

Mantenha baselines seguras e processo repetível para identificar, priorizar e remediar vulnerabilidades. Use risco, explorabilidade, exposição e criticidade para definir prioridade e governe exceções.

Capítulo 20 — Desenvolvimento seguro e gestão de mudanças

Integre segurança em aquisição, desenvolvimento e mudança. Defina revisão de arquitetura, código ou configuração, testes, dependências, segredos e aprovação de release conforme risco.

Capítulo 21 — Segurança de fornecedores e terceiros

Classifique fornecedores por acesso, criticidade, conectividade e concentração. Defina due diligence, requisitos contratuais, monitoramento, incidentes, subcontratação e término. Acompanhe achados até a remediação.

Capítulo 22 — Nuvem e responsabilidade compartilhada

Documente o modelo de responsabilidade compartilhada para cada serviço de nuvem. Governe identidades, configuração, criptografia, logs, redes, resiliência e backup. Não suponha que certificação do provedor elimine responsabilidades do cliente.

Capítulo 23 — Gestão de incidentes e evidências

Defina preparação, detecção, triagem, contenção, erradicação, recuperação, comunicação e lições aprendidas. Estabeleça severidade, funções, escalonamento e preservação de evidências.

Capítulo 24 — Continuidade e resiliência

Identifique dependências de segurança que suportam serviços críticos. Defina objetivos de recuperação, backup, alternativas, comunicações e requisitos de segurança durante interrupções. Teste cenários e remedie fraquezas.

Capítulo 25 — Interfaces de privacidade e regulação

Identifique onde privacidade, regulação setorial, compromissos contratuais ou leis locais afetam controles do SGSI. Mantenha registro de obrigações e vincule-as a políticas, riscos, controles, evidências e monitoramento.

Capítulo 26 — Monitoramento, medição e efetividade de controles

Defina métricas que mostrem se o SGSI e seus controles operam como esperado. Cada métrica deve ter proprietário, regra de cálculo, fonte, meta e limiar. Combine indicadores com testes de controle e tendências.

Capítulo 27 — Preparação para auditoria interna

Mantenha programa de auditoria baseado em escopo, risco, achados prévios e mudanças materiais. Assegure objetividade e competência. Defina critérios, população, amostragem, evidências, achados e acompanhamento.

Capítulo 28 — Análise crítica pela direção

Forneça à liderança revisão estruturada da adequação e eficácia do SGSI. Inclua auditorias, objetivos, riscos, incidentes, fornecedores, recursos, desempenho de controles, mudanças e oportunidades de melhoria.

Capítulo 29 — Não conformidade, ação corretiva e remediação

Quando requisitos ou processos não forem atendidos, registre o problema, contenha efeitos, identifique causa raiz, defina ação corretiva, atribua responsável e verifique eficácia. Não encerre achados apenas por existir plano.

Capítulo 30 — Melhoria contínua e gatilhos de mudança

Use incidentes, auditorias, métricas, mudanças tecnológicas, inteligência de ameaças, mudanças de negócio e lições aprendidas para melhorar o SGSI. Defina gatilhos formais de reavaliação.

Capítulo 31 — Arquitetura de evidências, caminhos de implementação e maturidade

Para cada objetivo material, mantenha cadeia rastreável: requisito ou risco, objetivo de controle, atividade, proprietário, frequência ou gatilho, fonte de evidência, revisor, exceção e gatilho de mudança. Diferencie evidência de desenho da evidência operacional.

Capítulo 32 — Release, localização, proveniência e reavaliação

A edição pt-BR deriva exclusivamente da fonte inglesa congelada identificada acima. Antes da publicação, verifique paridade estrutural e semântica, gere DOCX/PDF, execute QA de conteúdo, renderização, acessibilidade e visual, registre SHA-256, proveniência e resultados de workflows e coloque os binários exatos em `main` antes de promover catálogo ou registro de release.

Modelo de evidência controlada

contexto/requisito → risco → objetivo de controle → atividade de implementação → proprietário → frequência/gatilho → população → evidência → teste/revisão → exceção/remediação → gatilho de reavaliação